

Authentication Taxonomy Audit

Part 3 – Final Authentication Taxonomy

Family 1: GenAI-Powered Phishing (AUTH-001)

A. Identity

Field	Value
Attack ID	AUTH-001
Attack Family	GenAI-Powered Phishing
Attack Subtypes / Variants	Email phishing, SMS phishing (smishing), Social media phishing, Spear phishing, Business Email Compromise (BEC), AI-assisted AitM phishing, AI-generated phishing pages
Primary Lifecycle Stage	Authentication (Stage 4)
Secondary / Cross-stage Stages	Account Creation (Stage 2 – during onboarding), Payment Initiation (Stage 5 – post-takeover), Device/Session (Stage 3 – session token theft via AitM)
Target / Actor	End users (retail banking customers, corporate employees, high-net-worth individuals); Authentication factors (passwords, OTPs, session tokens)
Attack Objective	Steal authentication credentials (passwords, OTPs, session cookies) through AI-generated personalized phishing content, enabling account takeover and unauthorized transactions

B. Fraud Understanding

What is the attack?

Attackers use Generative AI (LLMs) to generate highly convincing, personalized phishing content at scale—emails, SMS messages, social media communications, and fake login pages—designed to steal authentication credentials. The AI-generated content has perfect grammar, correct branding, professional language, and contextual personalization that makes detection by traditional filters nearly impossible. 82.6% of phishing emails detected between September 2024 and February 2025 exhibited AI use. AI-generated phishing content rose from <5% to 56% of attempts during December 2025—a 14-fold increase.

Traditional mechanism:

Before GenAI, phishing relied on manually crafted emails with poor grammar, generic content, and detectable red flags. Phishing kits were template-based and required human effort for personalization. Detection relied on grammar/spelling checks and known phishing indicators.

GenAI transformation:

Dimension	Pre-GenAI	GenAI-Transformed
Content quality	Generic, poor grammar, detectable red flags	Perfect grammar, professional branding, context-aware
Personalization	Manual, minimal	AI-generated personalized content using OSINT
Scale	Human-limited, template-based	Thousands of unique, personalized messages
Adaptation	Static templates	Real-time adaptation based on detection feedback

Why GenAI is load-bearing:

If GenAI is removed, the attacker loses the ability to:

- Generate grammatically perfect, personalized phishing content at scale
- Craft context-aware messages referencing real colleagues, projects, or events
- Adapt linguistic patterns based on detection feedback
- Create thousands of unique phishing variants

The attack reverts to detectable template-based phishing.

HARD GenAI Removal Test result: PASS — GenAI creates a qualitatively new capability. The transformation from generic, detectable phishing to personalized, grammatically perfect content at scale is a qualitative leap.

Prerequisites:

- Access to GenAI tools (LLMs for content generation)
- Target intelligence (OSINT, breached data, LinkedIn, social media)
- Phishing distribution infrastructure (email, SMS, messaging platforms)
- (For AitM variant) Proxy infrastructure for real-time interception

Attack Flow:

1. Gather target intelligence (OSINT, breached data, social media)
2. Configure GenAI with target context (organization, roles, recent events)
3. Generate personalized phishing templates at scale
4. Deliver phishing content via email, SMS, or messaging platform
5. Content mimics legitimate institution (branding, language, urgency)
6. Redirects to fake authentication page or AitM proxy
7. User perceives message as legitimate and enters credentials/OTP
8. Credentials/OTP captured in real time
9. Attacker uses stolen credentials/OTP to access account
10. Account takeover → unauthorized transactions → funds theft

Downstream payment consequence:

Stolen credentials enable:

- Full account takeover and fund theft
- Unauthorized transactions to mule accounts
- Bypass of MFA (if OTP captured)
- Ongoing fraud from compromised account

C. DETECTION INTELLIGENCE

Observable Signals:

Signal Category	Specific Signals	Detection Method	Cross-account Needed?
Authentication Factor	OTP requests without corresponding user action; rapid OTP usage after phishing contact	Anomaly detection; Temporal correlation	No
Identity	Login attempts from unusual locations/devices after phishing contact	Rule-based + ML	No
Device	Device fingerprint changes between phishing interaction and login	Device fingerprint anomaly detection	No
Session	Rapid authentication after phishing contact; session anomalies	Temporal anomaly detection	No
Behavioral	Unusual navigation during login (searching for functions, hesitation)	Behavioral biometrics anomaly detection	No
Network	Phishing infrastructure patterns (domains, IPs, email headers); Domain reputation	Graph analytics; Threat intelligence	Yes – campaign identification
Temporal	Phishing message timing correlated with login attempts; off-hours weighting	Temporal correlation; Rule-based	Yes
Transaction Context	Unusual transactions following authentication	Transaction anomaly detection	Yes – beneficiary network analysis

Evasion Considerations (Defensive Threat Modeling):

An adaptive attacker might attempt to:

- Rotate phishing infrastructure (domains, IPs, email templates)
- Use legitimate-looking domains with typosquatting or homoglyph attacks
- Generate content mimicking specific internal communications using OSINT
- Adapt linguistic patterns after blocked attempts
- Use callback phishing (phone numbers) to avoid email filters
- Chain phishing with voice cloning for multi-channel attacks
- Leverage legitimate services (cloud storage, forms) to host phishing content

Legitimate Behavior That Could Look Similar:

Legitimate Scenario	Why It Looks Similar	False-Positive Risk
---------------------	----------------------	---------------------

Legitimate Scenario	Why It Looks Similar	False-Positive Risk
Legitimate bank communication	Correct branding and professional language	Flagging genuine bank emails
User-initiated password reset	OTP requests and login from new device	Blocking legitimate password resets
Travel/roaming	Login from unusual location	Flagging legitimate travelers
New device setup	Device fingerprint changes, OTP requests	Blocking legitimate device upgrades

D. SIMULATION INTELLIGENCE

Field	Value
Simulation Type	Agentic (primary)
Generation Parameters	Phishing type distribution; Personalization level; Content generation parameters; Target demographics; Delivery channel selection; AitM configuration
Synthetic Users	Victim personas (demographics, banking history, digital behavior patterns); Attacker personas
Synthetic Authentication Factors	Passwords, OTPs (SMS/email/authenticator), session tokens
Synthetic Authentication Events	Login attempts, OTP requests, password reset attempts, MFA challenges
Synthetic Device/Session Context	Device fingerprints, IP addresses, geolocation, session tokens, browser/user-agent patterns
Synthetic Behavioral Events	Phishing email generation → victim interaction → credential entry → login attempt → post-login activity
Synthetic Network Relationships	Phishing campaign infrastructure (domains, IPs); Correlation across victims; Credential reuse patterns
Synthetic Transaction Context	Post-takeover transaction sequences; Beneficiary additions; Funds movement patterns
Temporal Behavior	Time between phishing contact and credential use; Time of day patterns; Response latency
Attack Labels	Phishing type, personalization level, success/failure, detection evasion used, attack variant
Variant / Mutation Parameters	Channel (email/SMS/social/AitM); Personalization level; Infrastructure rotation; Linguistic style
Legitimate Counterpart	Legitimate banking communications, legitimate password resets, legitimate travel/roaming
Realistic Edge Cases	Partial phishing (user resists, reports), multi-channel attacks, AI-generated responses to user questions

E. EVIDENCE

Claim	Source	Publisher	Date	Evidence Type	Confidence
82.6% of phishing emails exhibited AI use	Cybersecurity research	Industry analysis	2025	Industry report	VERIFIED
AI-generated phishing content rose from <5% to 56% during December 2025	Cybersecurity research	Industry analysis	2025	Industry report	VERIFIED
14-fold increase in AI-generated phishing content	Cybersecurity research	Industry analysis	2025	Industry report	VERIFIED
Over 1 million online banking accounts compromised by infostealers	Kaspersky Digital Footprint Intelligence	Kaspersky	2025	Security research	VERIFIED
Fake e-shop pages dominated financial phishing at 48.5% (up 10.3% from 2024)	Kaspersky	Kaspersky	2025	Security research	VERIFIED
CoPHish technique leverages Microsoft Copilot Studio to craft OAuth-based credential theft	Security research	Industry analysis	2025	Security research	VERIFIED
VoidProxy uses AitM to intercept authentication flows	Okta security research	Okta	2025	Security research	VERIFIED

F. PRODUCT MAPPING

Component	Implementation
-----------	----------------

Component	Implementation
Generate	Agentic generation of phishing emails/SMS/messages; Parameterization by personalization level, channel, target demographics; AI-generated phishing page HTML
Defend	Email/SMS linguistic pattern analysis; Domain reputation scoring; Login timing anomaly detection; Device fingerprint analysis
Detection Approach	ML classification for AI-generated content patterns; Anomaly detection for login timing; Graph analytics for phishing infrastructure
Mitigation	Flag suspicious emails; Step-up authentication for high-risk logins; Block known phishing domains; User notification
Evaluation	Detection rate; False positive rate on legitimate communications; Time-to-detection

FAMILY 2: GENAI-POWERED OTP SOCIAL ENGINEERING (AUTH-002)

A. IDENTITY

Field	Value
Attack ID	AUTH-002
Attack Family	GenAI-Powered OTP Social Engineering
Attack Subtypes / Variants	Voice cloning vishing, Real-time voice conversion attacks, Bank official impersonation, Law enforcement impersonation (Digital Arrest scams), Family member impersonation
Primary Lifecycle Stage	Authentication (Stage 4)
Secondary / Cross-stage Stages	Identity/KYC (Stage 1 – voice biometric enrollment), Payment Initiation (Stage 5 – OTP for transaction authorization)
Target / Actor	Banking customers (particularly voice-biometric-enabled services); OTP delivery channels; Voice biometrics systems
Attack Objective	Use AI voice cloning and real-time dialogue generation to convince victims to reveal OTPs or authentication codes, enabling immediate account access and unauthorized transactions

B. FRAUD UNDERSTANDING

What is the attack?

Attackers use AI voice cloning (requiring as little as 3 seconds of audio) and real-time dialogue generation to impersonate bank officials, law enforcement, or trusted individuals via phone calls. The cloned voice convinces victims to share OTPs, authentication codes, or authorize transactions. Voice cloning can achieve over 80% attack success rate against voice authentication platforms. OpenAI CEO Sam Altman warned voiceprint authentication is "crazy" as AI-generated voices can easily bypass such systems.

Traditional mechanism:

Before GenAI, attackers used human callers with scripts to impersonate bank officials. Voice impersonation was limited by the attacker's vocal range, language skills, and scalability. Detection relied on recognizing unusual caller behavior or poor impersonation quality.

GenAI transformation:

Dimension	Pre-GenAI	GenAI-Transformed
Voice quality	Human impersonation, limited quality	AI voice clones indistinguishable from real
Language	Limited to attacker's languages	Any language with native fluency
Scalability	Human-limited (one caller at a time)	Automated calls at scale
Adaptation	Static scripts	Real-time dialogue adaptation
Training data	Required extensive recording	3 seconds sufficient for cloning

Why GenAI is load-bearing:

If GenAI is removed, the attacker loses the ability to:

- Generate convincing voice clones on demand (3-second sample sufficient)
- Conduct real-time, adaptive conversations in any language
- Scale attacks beyond human-caller limitations
- Adapt dialogue based on victim responses in real time

The attack reverts to human-caller social engineering with limited quality and scalability.

HARD GenAI Removal Test result: PASS — GenAI creates a qualitatively new capability. The transformation from human-limited voice impersonation to AI-generated, real-time voice cloning and dialogue is a qualitative leap.

Prerequisites:

- Voice samples of target or generic bank official (3 seconds sufficient)
- GenAI voice cloning tools
- Victim contact information
- AI-generated social engineering script (or real-time LLM dialogue)
- (For advanced) Real-time voice conversion during live calls

Attack Flow:

1. Obtain voice samples (social media, public recordings)
2. Clone victim or official voice using GenAI (3 seconds sufficient)
3. Generate personalized scam script (or use real-time dialogue generation)
4. Call victim impersonating bank official/law enforcement
5. Voice clone mimics bank representative or authority figure
6. Claims suspicious activity/account compromise
7. Requests OTP to "verify identity" or "reverse transaction"
8. Victim perceives caller as legitimate and shares OTP
9. Attacker uses OTP to complete authentication/authorization
10. Account takeover or unauthorized transaction completed

Downstream payment consequence:

OTP shared → immediate account access → funds transferred to mule accounts → account drained. OTP may also be used to authorize specific high-value transactions, bypassing transaction authentication.

C. DETECTION INTELLIGENCE

Observable Signals:

Signal Category	Specific Signals	Detection Method	Cross-account Needed?
Authentication Factor	OTP used shortly after voice call from unknown number; OTP request velocity	Temporal correlation; Anomaly detection	No
Identity	Caller ID spoofing (number matches bank but call fraudulent)	STIR/SHAKEN; Caller ID validation	Yes — carrier intelligence
Device	Device used for OTP receipt differs from usual	Device fingerprint anomaly	No
Session	Authentication immediately after OTP sharing	Temporal anomaly detection	No
Behavioral	Victim voice during subsequent verification shows distress/coercion	Voice stress analysis; Behavioral analytics	No
Network	Caller phone number associated with known scam patterns	Threat intelligence; Carrier data sharing	Yes
Temporal	Multiple OTP requests in short period; Calls at unusual hours	Velocity rules; Temporal anomaly	No
Transaction Context	Unusual transactions immediately after OTP-based authentication	Transaction anomaly detection	Yes — beneficiary network analysis

Evasion Considerations (Defensive Threat Modeling):

An adaptive attacker might attempt to:

- Use voice cloning with emotional nuance and intonation
- Spoof caller ID to match legitimate bank numbers
- Combine channels (email phishing + voice call for credibility)
- Target specific individuals with known voice patterns
- Use real-time voice conversion during live calls
- Adapt script based on victim responses using LLM-powered dialogue
- Call at times of high stress (late evening, weekends)
- Impersonate multiple roles (bank, law enforcement, family member)

Legitimate Behavior That Could Look Similar:

Legitimate Scenario	Why It Looks Similar	False-Positive Risk
Legitimate bank fraud alert call	Bank calls customer about suspicious activity	Flagging genuine bank calls

Legitimate Scenario	Why It Looks Similar	False-Positive Risk
Legitimate OTP verification	Customer receives and uses OTP for transaction	Blocking legitimate transactions
Customer-initiated password reset	OTP requested and used for account access	Blocking legitimate resets
Voice biometric enrollment	Customer provides voice sample	Flagging legitimate enrollment

D. SIMULATION INTELLIGENCE

Field	Value
Simulation Type	Agentic (primary)
Generation Parameters	Scam type distribution; Voice clone quality; Dialogue generation parameters; Call timing patterns; Channel selection
Synthetic Users	Victim personas (demographics, banking relationships, typical call behavior); Attacker personas; Bank official personas
Synthetic Authentication Factors	SMS OTP, email OTP, authenticator OTP, voice biometrics
Synthetic Authentication Events	OTP generation, OTP delivery, OTP entry, voice biometric verification, call interactions
Synthetic Device/Session Context	Caller ID, phone number, device used for OTP receipt, call duration, call timing
Synthetic Behavioral Events	Call initiation → script delivery → victim response → OTP request → OTP sharing → authentication attempt
Synthetic Network Relationships	Caller phone number networks (known scam numbers); victim phone number correlations
Synthetic Transaction Context	Post-OTP transaction sequences; Mule account transfers
Temporal Behavior	Call timing (off-hours weighted), call duration, time between call and OTP use
Attack Labels	Scam type, voice clone quality, script type, success/failure, channel used
Variant / Mutation Parameters	Voice clone quality; Impersonation type (bank/law enforcement/family); Script personalization; Real-time vs. pre-recorded
Legitimate Counterpart	Legitimate bank calls, legitimate OTP verification, legitimate customer support
Realistic Edge Cases	Partial success (some OTPs shared, not all); Victim resistance; Multi-channel attacks

E. EVIDENCE

Claim	Source	Publisher	Date	Evidence Type	Confidence
Voice cloning can achieve over 80% attack success rate against voice authentication	Academic research	IEEE/ACM	2025	Peer-reviewed research	VERIFIED
SMIA attack achieved ≥82% ASR against combined voice authentication/anti-spoofing	Academic research	IEEE/ACM	2025	Peer-reviewed research	VERIFIED
OpenAI CEO Sam Altman warned voiceprint authentication is "crazy"	OpenAI	Public statement	2025	Public statement	VERIFIED
Banks in Pune documented voice-based authentication bypass using synthetic audio	Local news/security reports	Indian media	2025	Industry report	VERIFIED
FBI warned AI-generated voice impersonations used to impersonate officials	FBI	FBI	2025	Government advisory	VERIFIED
SIM swap fraud surged 327% in Kenya in 2025	INTERPOL	INTERPOL	2025	Law enforcement report	VERIFIED
FBI logged 982 SIM swap complaints with \$26M losses in 2024	FBI IC3	FBI	2024	Government report	VERIFIED

F. PRODUCT MAPPING

Component	Implementation
Generate	Agentic generation of scam scripts and dialogue; Voice clone generation; Call interaction simulation
Defend	Caller ID validation (STIR/SHAKEN); OTP request velocity monitoring; Temporal correlation (call → OTP use); Voice biometric anomaly detection
Detection Approach	Anomaly detection for OTP usage patterns; Threat intelligence for caller reputation; Temporal correlation analysis
Mitigation	Delayed processing for high-risk OTP uses; Customer notification ("hang up and call back"); Step-up authentication
Evaluation	Detection rate; False positive rate on legitimate bank calls; Time-to-detection

FAMILY 3: GENAI-POWERED AUTHENTICATION RECOVERY EXPLOITATION (AUTH-003)

A. IDENTITY

Field	Value
Attack ID	AUTH-003
Attack Family	GenAI-Powered Authentication Recovery Exploitation
Attack Subtypes / Variants	Document-based recovery (forged ID/passport/DL); Voice-based recovery (voice clone); Video-based recovery (deepfake injection); Customer support impersonation; Hybrid recovery (multi-evidence)
Primary Lifecycle Stage	Authentication (Stage 4 – Recovery Surface)
Secondary / Cross-stage Stages	Identity/KYC (Stage 1 – document forgery overlap); Customer Support (Stage 18)
Target / Actor	Account recovery processes; Password reset flows; Factor replacement; Customer support identity verification; Document verification systems; Voice biometrics; Liveness detection
Attack Objective	Use GenAI-generated forged identity documents, voice clones, and deepfake videos to impersonate legitimate account holders during authentication recovery processes, enabling account takeover

B. FRAUD UNDERSTANDING

What is the attack?

Attackers use GenAI to generate convincing impersonation evidence on demand—forged identity documents, voice clones, and deepfake videos—to pass recovery verification and take over accounts. FATF’s December 2025 “Horizon Scan on AI and Deepfakes” specifically named liveness check as an attack surface. The MITRE ATLAS/iProov case study documented deepfake injection bypassing liveness checks. FINRA warns GenAI can create convincing fake ID documents for account takeovers. This is a qualitative leap from stolen PII to generated impersonation evidence.

Traditional mechanism:

Before GenAI, recovery-assisted account takeover relied on stolen PII (from data breaches), social engineering of support staff, or physical document forgery. Attackers were limited by the availability of stolen PII and the quality of physical/Photoshop forgeries.

GenAI transformation:

Dimension	Pre-GenAI	GenAI-Transformed
Documents	Stolen physical docs or Photoshop forgeries	Photorealistic forged documents on demand
Voice	Human impersonation or stolen recordings	Voice clones from 3-second samples
Video	Physical spoofs (photos, masks)	Deepfake injection bypassing liveness
Scale	Labour-intensive, limited	Automated, on-demand generation for any identity

Why GenAI is load-bearing:

If GenAI is removed, the attacker loses the ability to:

- Generate convincing forged identity documents without specialized skills or stolen documents
- Create voice clones on demand for phone-based recovery
- Produce deepfake video for video-based recovery verification
- Generate impersonation evidence at scale

The attack reverts to PII-based recovery abuse with limited quality and scalability.

HARD GenAI Removal Test result: PASS — GenAI creates a qualitatively new capability. The transformation from stolen-PII-based recovery abuse to on-demand generation of perfect impersonation evidence is a qualitative leap.

Prerequisites:

- Victim PII (from data breaches, social media, OSINT)
- Access to GenAI tools: document generation, voice cloning, deepfake video
- Knowledge of target institution’s recovery verification process

Attack Flow:

1. Obtain victim PII (data breach, social media, OSINT)

- 2. Generate forged identity documents (passport, DL, utility bills)
- 3. Create voice clone of victim (if voice verification used)
- 4. Create deepfake video of victim (if video verification used)
- 5. Initiate account recovery (password reset, factor replacement)
- 6. Submit forged documents via upload
- 7. (Voice variant) Pass phone verification with voice clone
- 8. (Video variant) Pass video verification with deepfake injection
- 9. Recovery verification bypassed; password/factors reset
- 10. Attacker logs in with new credentials; victim locked out
- 11. Funds transferred to mule accounts

Downstream payment consequence:

Recovery bypass → full account takeover → funds drained → new beneficiaries added → ongoing fraud from compromised account.

C. DETECTION INTELLIGENCE

Observable Signals:

Signal Category	Specific Signals	Detection Method	Cross-account Needed?
Authentication Factor	Recovery initiated from unusual device/location; Multiple recovery attempts	Rule-based + ML; Velocity rules	No
Identity	Forged document artifacts (pixel anomalies, inconsistent metadata, unnatural aging)	CNN/Transformer document forensics	Yes – document fingerprinting
Device	Virtual camera detection (for video recovery); Device emulation	Hardware-level sensor validation; Rule-based	No
Session	Rapid completion of recovery flow (superhuman speed)	Temporal anomaly detection	No
Behavioral	Unnatural facial movements (lack of micro-expressions, audio-visual desync)	Deepfake detection (CNN/Transformer); Behavioral biometrics	Yes – artifact pattern matching
Network	Recovery attempts connected to known fraud patterns	Graph analytics; Threat intelligence	Yes
Temporal	Recovery at unusual hours; Multiple recovery attempts	Velocity rules; Temporal anomaly	Yes
Transaction Context	Unauthorized transactions immediately after recovery	Transaction anomaly detection	Yes – beneficiary network analysis

Evasion Considerations (Defensive Threat Modeling):

An adaptive attacker might attempt to:

- Generate documents with realistic aging/noise effects to evade pixel-level detection
- Use varied deepfake patterns to avoid fingerprinting
- Add realistic micro-expressions and natural head movements to deepfake videos
- Rotate virtual camera configurations to evade detection
- Use non-rooted Android devices to avoid basic device integrity checks
- Combine multiple GenAI techniques (documents + voice + video)
- Adapt based on detection feedback—improving quality after failed attempts

Legitimate Behavior That Could Look Similar:

Legitimate Scenario	Why It Looks Similar	False-Positive Risk
Legitimate password reset	User forgets password, initiates recovery	Blocking legitimate recovery attempts
Legitimate lost device recovery	User gets new phone, needs factor replacement	Blocking legitimate device changes
Legitimate travel	Recovery from unusual location	Flagging legitimate travelers
Legitimate document renewal	Upload of new ID documents	Flagging legitimate document updates
Poor camera quality/lighting	Deepfake detection may falsely flag	Blocking users with legitimate technical issues

D. SIMULATION INTELLIGENCE

Field	Value
Simulation Type	Agentic (primary) + Algorithmic (document/video generation)

Field	Value
Generation Parameters	Document type distribution; Forgery quality levels; Voice clone quality; Deepfake quality; Recovery channel selection; Verification interaction parameters
Synthetic Users	Victim personas (legitimate account holders); Attacker personas
Synthetic Authentication Factors	Forged identity documents (passport, DL, utility bills); Voice clone audio; Deepfake video
Synthetic Authentication Events	Recovery initiation, document submission, voice verification, video verification, password/factor reset, post-recovery login
Synthetic Device/Session Context	Device fingerprint (spoofed or real); Virtual camera detection indicators; IP/location spoofing
Synthetic Behavioral Events	Recovery initiation → document upload → verification → reset → login → post-recovery activity
Synthetic Network Relationships	Recovery attempts connected to fraud patterns; Same document/deepfake artifacts across attempts
Synthetic Transaction Context	Post-recovery unauthorized transactions; New beneficiary additions; Funds movement
Temporal Behavior	Recovery timing (off-hours weighted); Verification duration; Time-to-fraud
Attack Labels	Recovery type; GenAI evidence quality (document/voice/video); Success/failure; Detection evasion used
Variant / Mutation Parameters	Recovery channel (document/voice/video/hybrid); Evidence quality; Impersonation sophistication
Legitimate Counterpart	Legitimate password reset; Lost device recovery; Legitimate document updates
Realistic Edge Cases	Partial recovery attempts; Multiple recovery channels; Injection attempts partially successful

E. EVIDENCE

Claim	Source	Publisher	Date	Evidence Type	Confidence
FATF Horizon Scan on AI and Deepfakes named liveness check as attack surface	FATF Horizon Scan	FATF	Dec 2025	Government report	VERIFIED
MITRE ATLAS/iProov case study: deepfake injection bypassing liveness	MITRE ATLAS / iProov	MITRE	2025	Security case study	VERIFIED
Attack uses Faceswap + OBS + Virtual Camera on non-rooted Android	iProov / MITRE ATLAS	MITRE	2025	Security case study	VERIFIED
FINRA warns GenAI can create convincing fake ID documents for account takeovers	FINRA	FINRA	2025	Regulatory advisory	VERIFIED
RBI August 2025 amendment mandated active deepfake/spoof detection in V-CIP	RBI KYC Master Direction	RBI	Aug 2025	Regulatory mandate	VERIFIED
Deepfakes account for 20% of biometric fraud attempts	Entrust 2026 Identity Fraud Report	Entrust	2026	Industry report	VERIFIED
Deepfake selfies increased 58% in 2025	Entrust 2026 Identity Fraud Report	Entrust	2026	Industry report	VERIFIED
Injection attacks increased 40% YoY	Entrust 2026 Identity Fraud Report	Entrust	2026	Industry report	VERIFIED
FBI reports attackers use phishing to convince victims to share login info/MFA codes	FBI	FBI	2025	Government advisory	VERIFIED

F. PRODUCT MAPPING

Component	Implementation
Generate	Agentic generation of recovery scenarios; Algorithmic generation of forged documents; Voice clone generation; Deepfake video generation
Defend	Document forensics (CNN/Transformer); Deepfake detection; Voice biometric anomaly detection; Recovery context risk scoring
Detection Approach	Multi-modal anomaly detection (document + voice + video); Graph analytics for recovery attempt correlation; Temporal anomaly detection
Mitigation	Enhanced verification for recovery; Delayed recovery processing; Manual review; Customer notification; Block
Evaluation	False Acceptance Rate (FAR); False Rejection Rate (FRR); Detection Rate; Time-to-Detection

FAMILY 4: GENAI-POWERED BIOMETRIC SPOOFING (AUTH-004)

A. IDENTITY

Field	Value
Attack ID	AUTH-004
Attack Family	GenAI-Powered Biometric Spoofing
Attack Subtypes / Variants	GAN-based keystroke injection; GAN-based facial injection; GAN-based voice cloning; Motion forecasting attacks; Adversarial behavioral pattern generation; Synthetic fingerprint/iris generation
Primary Lifecycle Stage	Authentication (Stage 4)
Secondary / Cross-stage Stages	Identity/KYC (Stage 1 – biometric verification during onboarding); Device/Session (Stage 3 – behavioral biometrics in session)
Target / Actor	Biometric authentication systems (keystroke dynamics, facial recognition, voice biometrics, fingerprint/iris); Behavioral biometrics; Liveness detection
Attack Objective	Generate synthetic biometric data matching legitimate user profiles to bypass biometric authentication without requiring access to the user’s actual biometric data

B. FRAUD UNDERSTANDING

What is the attack?

Attackers use GANs (Generative Adversarial Networks) and other GenAI techniques to generate synthetic biometric data—keystroke patterns, facial images, voice recordings, fingerprint data—that mimics legitimate users with sufficient fidelity to bypass biometric authentication systems. GANs can replicate user-specific typing rhythms and fool authenticators with 95-96% accuracy. LSTM-GAN consistently performed best (95-96%), followed by CNN-GAN (92-94%). AdvFaceGAN demonstrates GAN-based dual-identity impersonation attacks bypassing defenses. Unlike traditional presentation attacks, GenAI enables digital injection that bypasses the physical sensor entirely.

Traditional mechanism:

Before GenAI, biometric spoofing relied on presentation attacks: printed photos for facial recognition, 3D masks, voice recordings, and fingerprint lifts. These were detectable by basic liveness detection (blink detection, 3D depth sensing, spectral analysis).

GenAI transformation:

Dimension	Pre-GenAI	GenAI-Transformed
Keystroke patterns	Statistical mimicry, detectable	GAN-generated patterns, 95-96% accuracy
Facial images	Physical photos/masks	Digital deepfake injection
Voice	Recorded voice replay	AI-generated voice clones
Fingerprint	Physical lifts/prints	GAN-generated synthetic fingerprints
Injection	Physical presentation	Digital sensor bypass (camera injection, API injection)

Why GenAI is load-bearing:

If GenAI is removed, the attacker loses the ability to:

- Generate indistinguishable behavioral patterns (GAN-quality keystroke and motion patterns)
- Learn and replicate specific individual user behavior patterns
- Generate synthetic facial images/video that pass liveness detection
- Generate fingerprints/iris patterns indistinguishable from real
- Perform injection attacks that bypass the physical sensor

The attack reverts to detectable physical presentation attacks.

HARD GenAI Removal Test result: PASS — GenAI creates a qualitatively new capability. The transformation from detectable physical spoofing to GAN-generated indistinguishable synthetic biometrics is a qualitative leap. For keystroke dynamics, the attack effectively did not exist before GenAI.

Prerequisites:

- Access to GAN/GenAI models for biometric generation
- Training data (general human behavior patterns or specific victim data)
- Ability to inject generated biometric data into the authentication pipeline
- Understanding of target biometric system

- (For facial) Virtual camera injection capability

Attack Flow:

1. Obtain training data (general human behavior or specific victim patterns)
2. Train GAN on target biometric patterns (keystroke timing, facial features, voice)
3. Generate synthetic biometric data matching target profile
4. (Keystroke variant) Inject synthetic keystroke patterns during login
5. (Facial variant) Inject deepfake video via virtual camera
6. (Voice variant) Play cloned voice during verification
7. Biometric system compares input against stored template
8. GAN-generated pattern matches within acceptance threshold
9. Liveness detection (if present) accepts synthetic input
10. Authentication successful; attacker gains account access
11. Unauthorized transactions → funds theft

Downstream payment consequence:

Biometric bypass → account access without credential theft → unauthorized transactions → funds transferred → difficult to detect post-hoc.

C. DETECTION INTELLIGENCE

Observable Signals:

Signal Category	Specific Signals	Detection Method	Cross-account Needed?
Authentication Factor	Biometric match within threshold but with subtle anomalies; Pattern "too perfect"	ML anomaly detection; Adversarial pattern detection	No
Identity	Biometric pattern inconsistent with historical profile	ML anomaly detection; Behavioral biometrics	No
Device	Virtual camera detection (for facial injection)	Hardware-level sensor validation	No
Session	Session anomalies (pattern changes)	Session anomaly detection	No
Behavioral	Keystroke timing "too perfect" (unusually consistent); Mouse movement unnatural; Cross-modality inconsistency	ML anomaly detection; Cross-modality consistency checking	No
Network	N/A (per-session evasion)	N/A	No
Temporal	Biometric patterns too consistent over time (lack of natural drift)	Temporal consistency analysis	No
Transaction Context	Transactions inconsistent with behavioral biometric profile	Cross-modal consistency checking	No

Evasion Considerations (Defensive Threat Modeling):

An adaptive attacker might attempt to:

- Generate patterns with natural variance to avoid "too perfect" detection
- Train on specific victim's biometric data for personalized attacks
- Adapt GAN outputs based on detection feedback (adversarial training)
- Combine multiple biometric modalities for consistency
- Use increasingly sophisticated GAN architectures (LSTM-GAN, CNN-GAN)
- Vary injection methods (camera injection, audio injection, direct API calls)
- Add subtle imperfections to mimic real biometric variance

Legitimate Behavior That Could Look Similar:

Legitimate Scenario	Why It Looks Similar	False-Positive Risk
Legitimate user behavior	By definition, matches user baseline	Flagging legitimate behavior
User with variable behavior	New device, new app, fatigue	Flagging legitimate variance
Accessibility tools	Unusual interaction patterns	Blocking users with disabilities
Physical conditions	Affects keystroke/mouse patterns	Flagging legitimate medical conditions
New device	New biometric enrollment	Blocking legitimate device upgrades

D. SIMULATION INTELLIGENCE

Field	Value
Simulation Type	Hybrid (Algorithmic for GAN generation + Agentic for injection)
Generation Parameters	Keystroke timing distributions; Mouse movement parameters; Touch gesture patterns; Facial image/video quality; Voice spectral features; Fingerprint pattern parameters
Synthetic Users	Victim personas (legitimate users with biometric profiles); Attacker personas
Synthetic Authentication Factors	Keystroke patterns, mouse movements, touch gestures, facial images/video, voice, fingerprint/iris patterns
Synthetic Authentication Events	Biometric enrollment, biometric verification, liveness checks, continuous authentication
Synthetic Device/Session Context	Device fingerprint; Camera feed (real vs. virtual); Microphone input; Session context
Synthetic Behavioral Events	Keystroke timing sequences; Mouse movement paths; Touch gesture patterns; Facial expressions/movements; Voice patterns
Synthetic Network Relationships	N/A (per-session evasion)
Synthetic Transaction Context	Transaction sequences consistent with behavioral profile (to avoid detection)
Temporal Behavior	Keystroke timing distributions; Response latency; Session timing patterns
Attack Labels	Biometric type (keystroke/facial/voice/fingerprint); GAN architecture; Mimicry quality; Injection method; Success/failure
Variant / Mutation Parameters	Biometric modality; Mimicry quality; Injection method; Training data source (general vs. specific user)
Legitimate Counterpart	Legitimate user behavior (baseline); Users with variable behavior; Accessibility tool users
Realistic Edge Cases	Partial behavioral mimicry; Variable behavior across contexts; Accessibility tools; Physical conditions affecting behavior; New devices

E. EVIDENCE

Claim	Source	Publisher	Date	Evidence Type	Confidence
GANs replicate user-specific typing rhythms with 95-96% accuracy	IEEE	IEEE	2025	Peer-reviewed research	VERIFIED
LSTM-GAN best (95-96%), CNN-GAN (92-94%)	IEEE	IEEE	2025	Peer-reviewed research	VERIFIED
AdvFaceGAN demonstrates GAN-based dual-identity impersonation attacks	Academic research	arXiv/IEEE	2025	Peer-reviewed research	VERIFIED
MITRE ATLAS/iProov: deepfake injection bypassing liveness	MITRE ATLAS / iProov	MITRE	2025	Security case study	VERIFIED
Practical GAN-based Presentation Attacks on Typing Biometrics	IEEE	IEEE	2025	Peer-reviewed research	VERIFIED
Robot adversarial attack on keystroke dynamics based user authentication	University of Glasgow	University of Glasgow	2025	Academic research	VERIFIED
Motion Forecasting Attacks on Behavioral Biometric Authentication	ACM	ACM	2025	Peer-reviewed research	VERIFIED
Deepfakes account for 20% of biometric fraud attempts	Entrust 2026 Identity Fraud Report	Entrust	2026	Industry report	VERIFIED
Iris biometric systems compromised by StyleGAN-generated presentation attacks	Academic research	IEEE	2025	Peer-reviewed research	VERIFIED
Foundation models misused to generate synthetic biometric data	Industry analysis	Security industry	2025	Industry report	REASONABLE INFERENCE

F. PRODUCT MAPPING

Component	Implementation
Generate	GAN-based generation of keystroke/mouse/touch patterns; Algorithmic parameterization of behavioral patterns; Agentic injection of generated patterns into sessions; Deepfake video generation
Defend	Behavioral biometrics anomaly detection; Cross-modality consistency checking; ML classification for GAN-generated patterns; Deepfake detection (CNN/Transformer); Hardware-level sensor validation

Component	Implementation
Detection Approach	ML anomaly detection for keystroke/mouse/touch patterns; Cross-modality consistency checking; Adversarial pattern detection; Temporal consistency analysis
Mitigation	Step-up authentication for behavioral anomalies; Enhanced monitoring for pattern inconsistencies; Multi-factor verification for high-risk sessions
Evaluation	False Acceptance Rate (FAR); False Rejection Rate (FRR); Detection Rate; Equal Error Rate (EER)

PART 4 – FINAL COVERAGE AUDIT

Authentication Attack Surface	Considered?	Covered By	Separate Family?	Reason
Password authentication	✓	AUTH-001	No	Compromised via GenAI-powered phishing
Credential stuffing	✓	MERGED → AUTH-001	No	GenAI enhances evasion but not transformative; variant of credential theft
Password spraying	✓	MERGED → AUTH-001	No	Same mechanism as credential-based attacks
Stolen credentials	✓	MERGED → AUTH-001	No	Downstream consequence; GenAI enhances theft via phishing
Phishing	✓	AUTH-001	Yes	GenAI-enabled personalized content is distinct
OTP (general)	✓	AUTH-001, AUTH-002	No	Covered by phishing and social engineering families
SMS OTP	✓	AUTH-001, AUTH-002	No	Covered by both families
Email OTP	✓	AUTH-001	No	Covered by phishing family
Authenticator apps	✓	AUTH-001	No	Covered by phishing family
Push authentication	✓	DROPPED	No	MFA fatigue exists without GenAI; automation is incremental
MFA	✓	AUTH-001, AUTH-002, AUTH-004	No	Covered by multiple families
MFA fatigue / push bombing	✓	DROPPED	No	Core attack exists without GenAI
SIM swap	✓	DROPPED	No	GenAI enhances but core attack exists without it
OTP interception (SS7/Fake BTS)	✓	DROPPED	No	GenAI not load-bearing
Adversary-in-the-middle (AitM)	✓	MERGED → AUTH-001	No	GenAI improves phishing content; variant of Family 1
Passkeys / FIDO / WebAuthn	✓	DROPPED	No	No GenAI load-bearing evidence for passkey compromise
Biometric authentication	✓	AUTH-004	Yes	GAN-generated synthetic biometrics are distinct
Biometric spoofing	✓	AUTH-004	Yes	GenAI enables indistinguishable synthetic biometrics
Authentication-factor theft	✓	AUTH-001	No	Covered by phishing family
Factor enrollment	✓	DROPPED	No	GenAI not load-bearing
Factor replacement	✓	MERGED → AUTH-003	No	GenAI enhances but attack exists; variant of recovery
Password reset	✓	AUTH-003	Yes	GenAI on-demand impersonation evidence is distinct
Authentication recovery	✓	AUTH-003	Yes	GenAI on-demand impersonation evidence is distinct
Trusted authentication factors	✓	AUTH-003	No	Covered by recovery exploitation
Account takeover	✓	AUTH-001, AUTH-003	No	Downstream consequence
Session/token abuse (Auth primary)	✓	DROPPED	No	GenAI not load-bearing
Customer-support-assisted authentication	✓	MERGED → AUTH-003	No	GenAI enhances but attack exists; variant of recovery
Adaptive/risk-based authentication	✓	MOVED → Device/Session	No	Risk score manipulation covered by BBE-001
Step-up authentication	✓	MOVED → Device/Session	No	Covered by BBE-001

PART 5 – FINAL SUMMARY

Table 1 – FINAL AUTHENTICATION ATTACK TAXONOMY

ID	Attack Family	Variants	GenAI Classification	Simulation Type	Primary Stage	Reason for Distinctness
AUTH-001	GenAI-Powered Phishing	Email phishing; SMS phishing; Social media phishing; Spear phishing; BEC; AI-assisted AitM phishing	PASS	Agentic	Authentication	GenAI enables personalized, grammatically perfect phishing at scale—qualitative leap from generic phishing
AUTH-002	GenAI-Powered OTP Social Engineering	Voice cloning vishing; Real-time voice conversion; Bank/law enforcement impersonation; Digital Arrest scams	PASS	Agentic	Authentication	GenAI enables convincing voice cloning from 3-second samples + real-time dialogue—qualitative leap from human callers
AUTH-003	GenAI-Powered Authentication Recovery Exploitation	Document-based recovery; Voice-based recovery; Video-based recovery; Customer support impersonation; Hybrid recovery	PASS	Agentic + Algorithmic	Authentication (Recovery)	GenAI enables on-demand generation of forged documents, voice clones, deepfakes—qualitative leap from stolen PII
AUTH-004	GenAI-Powered Biometric Spoofing	GAN-based keystroke injection; GAN-based facial injection; GAN-based voice cloning; Motion forecasting; Synthetic fingerprint/iris	PASS	Hybrid	Authentication	GenAI (GANs) enables indistinguishable synthetic biometrics (95-96% accuracy)—did not exist before GenAI

Total: 4 final Authentication attack families

Table 2 – ATTACK × OBSERVABLE SIGNAL

Attack Family	Auth Factor	Device	Session	Behavioral	Transaction	Network	Temporal
AUTH-001: GenAI-Powered Phishing	OTP request anomalies; Rapid credential use	Device fingerprint changes	Session anomalies	Unusual navigation during login	Post-takeover fraud	Phishing infrastructure patterns; Domain reputation	Phishing-contact-to-login correlation; Off-hours
AUTH-002: OTP Social Engineering	OTP used shortly after voice call; OTP velocity	OTP receipt device changes	Rapid authentication post-call	Victim voice distress/coercion	Post-OTP unauthorized transactions	Caller ID reputation; Carrier intelligence	Call timing; Call-to-OTP-use time
AUTH-003: Recovery Exploitation	Recovery from unusual device/location	Virtual camera detection; Device emulation	Superhuman recovery speed	Unnatural facial movements; Deepfake artifacts	Post-recovery fraud	Recovery attempts connected to fraud patterns	Recovery timing (off-hours); Multiple attempts
AUTH-004: Biometric Spoofing	Biometric match anomalies; "Too perfect" patterns	Virtual camera detection	Session pattern changes	Keystroke/mouse/touch anomalies; Cross-modality inconsistency	Transaction-biometric inconsistency	N/A (per-session)	Biometric pattern consistency over time

Table 3 – ATTACK × SIMULATION

Attack Family	Synthetic Users	Auth Factors	Auth Events	Device/Session	Behavioral Events	Network	Agentic/Algorithmic/Hybrid
AUTH-001	Victim personas; Attacker personas	Passwords; OTPs; Session tokens	Login attempts; OTP requests; MFA challenges	Device fingerprints; IPs; Browser patterns	Phishing generation → interaction → credential entry → login	Campaign infrastructure; Victim correlations	Agentic
AUTH-002	Victim personas; Attacker personas; Bank personas	SMS OTP; Email OTP; Authenticator OTP; Voice biometrics	OTP generation/delivery/entry; Voice verification; Call interactions	Caller ID; Phone number; OTP device	Call initiation → script → OTP request → OTP sharing → auth	Caller phone networks; Scam number correlations	Agentic

Attack Family	Synthetic Users	Auth Factors	Auth Events	Device/Session	Behavioral Events	Network	Agentic/Algorithmic/Hybrid
AUTH-003	Victim personas; Attacker personas	Forged documents; Voice clones; Deepfake video	Recovery initiation; Document/voice/video verification; Password reset	Spoofed device fingerprint; Virtual camera; IP/location spoofing	Recovery → upload → verification → reset → login → post-recovery	Recovery attempt correlations; Artifact fingerprinting	Agentic + Algorithmic
AUTH-004	Victim personas; Attacker personas	Keystroke patterns; Facial images/video; Voice; Fingerprint/iris	Biometric enrollment; Biometric verification; Liveness checks	Device fingerprint; Camera feed; Microphone input	Keystroke/mouse/touch patterns; Facial expressions; Voice patterns	N/A (per-session)	Hybrid

Table 4 – TAXONOMY DECISIONS

Candidate	Decision	Reason
GenAI-Powered Phishing	KEEP (AUTH-001)	PASS; personalized AI-generated content is qualitatively new
GenAI-Powered OTP Social Engineering	KEEP (AUTH-002)	PASS; voice cloning + real-time dialogue is qualitatively new
GenAI-Powered Authentication Recovery Exploitation	KEEP (AUTH-003)	PASS; on-demand impersonation evidence is qualitatively new
GenAI-Powered Biometric Spoofing	KEEP (AUTH-004)	PASS; GAN-generated synthetic biometrics are qualitatively new
Credential Stuffing (enhanced)	MERGE → AUTH-001	PARTIAL; AI enhances evasion but not transformative
Password Spraying (enhanced)	MERGE → AUTH-001	PARTIAL; same mechanism as credential-based attacks
Infostealers (AI-assisted)	MERGE → AUTH-001	PARTIAL; AI lowers barrier but doesn't change mechanism
AitM Phishing (AI-enhanced)	MERGE → AUTH-001	PARTIAL; AI improves phishing content
TOTP Theft (AI-enhanced)	MERGE → AUTH-001	PARTIAL; AI improves phishing content
SIM Swap (voice-enhanced)	DROP	PARTIAL; core attack exists without GenAI
MFA Fatigue (AI-automated)	DROP	PARTIAL; core attack exists without GenAI
SS7 Interception	DROP	FAIL; GenAI not load-bearing
Fake BTS	DROP	FAIL; GenAI not load-bearing
Factor Replacement (AI-enhanced)	MERGE → AUTH-003	PARTIAL; recovery process abuse enhanced by GenAI
Help-Desk Social Engineering	MERGE → AUTH-003	PARTIAL; recovery/support impersonation enhanced by GenAI
Biometric Replay (AI-generated)	MERGE → AUTH-004	PARTIAL; GenAI improves generation of synthetic biometrics
Credential-Based ATO	MERGE → AUTH-001	PARTIAL; downstream consequence of phishing
MFA Bypass ATO	DROP	PARTIAL; consequence of multiple attacks; not distinct
Session Hijacking	DROP	FAIL; GenAI not load-bearing
OAuth Token Abuse	DROP	FAIL; GenAI not load-bearing
Risk Score Manipulation	MOVE → Device/Session	Covered by existing BBE-001 family

FINAL SUMMARY

Metric	Value
Total final attack families	4
Total variants	18 (across 4 families)
Important candidates merged	Credential Stuffing → AUTH-001; Password Spraying → AUTH-001; Infostealers → AUTH-001; AitM Phishing → AUTH-001; TOTP Theft → AUTH-001; Factor Replacement → AUTH-003; Help-Desk Social Engineering → AUTH-003; Biometric Replay → AUTH-004
Important candidates moved	Risk Score Manipulation → Device/Session (BBE-001)
Important candidates dropped	SIM Swap (voice-enhanced); MFA Fatigue; SS7 Interception; Fake BTS; Stolen Authentication Device; Factor Enrollment Abuse; Session Hijacking; OAuth Token Abuse

Metric	Value
Theoretical/future threats	None identified; all kept families have verified evidence
Remaining research gaps	Real-world frequency of GAN-based behavioral evasion in financial fraud; Specific detection evasion effectiveness against production biometric systems; Impact of emerging GAN architectures on detection accuracy

Final Note on Taxonomy Consistency

The Authentication taxonomy has **4 families**, emerging naturally from evidence and the HARD GenAI Removal Test—not forced. This is consistent with:

- Identity/KYC = 5 families
- Account Creation/Onboarding = 3 families
- Device/Session = 5 families
- Authentication = 4 families

Each of the 4 Authentication families represents a distinct attack mechanism with load-bearing GenAI transformation, strong evidence, and simulation feasibility.

The unifying theme across all 4 Authentication families is the shift from **"detectable impersonation"** to **"indistinguishable generation"**—fraudsters no longer rely on stolen PII, poor-quality forgeries, or human-limited social engineering; they use GenAI to generate perfect impersonation evidence on demand, at scale, in real time.